

Task 4: Incident Response Plan (IRP)

This plan provides a structured, step-by-step approach to managing security incidents efficiently to limit damage and reduce recovery time.

1. Detection

The goal is to identify a potential security incident as early as possible.

- **Indicators of Compromise (IoCs):** Look for unusual network traffic spikes, unauthorized access logs, repetitive failed login attempts, or unexpected system configurations.
- **Alerting Channels:** Automated alerts from Endpoint Detection and Response (EDR) systems, Firewalls, or Security Information and Event Management (SIEM) tools.
- **Verification:** The Incident Response Team (IRT) quickly assesses the alert to confirm if it is a true security incident or a false positive.

2. Reporting

Clear communication channels ensure that the right people are notified without creating unnecessary panic.

- **Internal Escalation:** Employees report anomalies to the IT/Security Helpdesk. High-severity events are immediately escalated to the Incident Commander.
- **External Notification:** If sensitive data or Personally Identifiable Information (PII) is compromised, the Legal and

Compliance teams determine reporting timelines for regulatory bodies (e.g., GDPR, HIPAA, or local data protection authorities) and affected customers.

- **Documentation:** Log all details in a centralized incident ticketing system (Time of detection, systems involved, observed behaviour).

3. Containment

The primary objective here is to "stop the bleeding" and prevent the threat from spreading further into the network.

- **Short-Term Containment:** Isolate affected devices from the local network and internet (e.g., disconnect network cables or place endpoints in an isolated VLAN).
- **Long-Term Containment:** Apply temporary security patches, disable compromised user accounts, and close specific firewall ports being utilized by the attacker.

4. Eradication

Once the threat is contained, you must completely remove the root cause of the incident from the environment.

- **Threat Removal:** Delete malware, malicious artifacts, and rogue registry keys.
- **Vulnerability Remediation:** Patch the initial entry point (e.g., update vulnerable software or fix misconfigured cloud buckets).
- **Identity Reset:** Force a global password reset for all compromised or highly privileged accounts.

5. Recovery

This phase focuses on safely restoring systems back to normal production operations.

- **System Restoration:** Restore systems from clean, verified backups.
- **Validation:** Continuous monitoring of restored systems for a set period (e.g., 48–72 hours) to ensure the threat does not resurface.
- **Phased Reconnection:** Gradually bring systems back online to closely monitor network behaviour.

6. Lessons Learned

Often overlooked, this is the most critical phase for improving long-term security posture.

- **Post-Incident Review:** Hold a meeting with the IRT and stakeholders within 1 to 2 weeks of the incident.
- **Key Questions:** What went well? Where did the plan fail? How can we prevent this exact type of incident from happening again?
- **Plan Updates:** Update this Incident Response Plan and adjust security controls based on the findings.

Task 5: Security Awareness Training Outline

Target Audience: All Employees

Module 1: Phishing Awareness

- **The Concept:** Explaining how attackers use deceptive emails, texts (Smishing), or phone calls (Vishing) to steal credentials or install malware.
- **Red Flags:** Urgency/fear tactics, generic greetings, mismatched sender email domains, and suspicious attachments/links.
- **Action Items:** Hover over links before clicking; never enter credentials on unverified pages; use the internal "Report Phishing" button.

Module 2: Password Security & Identity Protection

- **Password Strength:** Moving away from short, complex passwords to long, memorable **Passphrases** (e.g., Correct-Horse-Battery-Staple).
- **The Golden Rule:** Never reuse passwords across corporate and personal accounts.
- **Multi-Factor Authentication (MFA):** How MFA acts as the ultimate second line of defence, and how to handle MFA push-notification fatigue (never approve a prompt you didn't trigger).

Module 3: Safe Internet Usage

- **Secure Connections:** Understanding the difference between HTTP and HTTPS. Avoid using public Wi-Fi networks without an approved corporate VPN.
- **Shadow IT:** The dangers of downloading unauthorized software or uploading sensitive corporate data into unvetted public AI tools or cloud storage.
- **Social Engineering on the Web:** Recognizing fake update pop-ups or malicious search engine results.

Module 4: Device & Physical Security

- **Lock Before You Walk:** Emphasizing the habit of locking screens (Win + L or Cmd + Ctrl + Q) every time an employee leaves their desk.
- **Physical Theft Prevention:** Safe handling of company laptops in public spaces (cars, coffee shops, airports).
- **Removable Media:** A strict policy against plugging unknown USB drives into company machines ("Don't pick up USB sticks in the parking lot").

Module 5: Incident Reporting (What to do when things go wrong)

- **No-Blame Culture:** Cultivating an environment where employees aren't afraid to admit they clicked a bad link. Early reporting saves data.
- **How to Report:** Clear instructions on how to reach the Security/IT team (Specific email extension, internal phone extension, or ticketing portal).

- **Immediate Action:** If a screen locks up with a ransom note or starts behaving erratically, disconnect the network immediately and call IT.